

|                                                                                                      |                                                             |                                           |
|------------------------------------------------------------------------------------------------------|-------------------------------------------------------------|-------------------------------------------|
|                     | <b>Aplicación Web Evaluada:</b> NOMBRE DEL SITIO / PROYECTO | <b>Fecha de Auditoría:</b><br>02/07/20025 |
| <b>Responsable de Auditoría:</b> Tu nombre y cargo (Ej: Bastián Landskron - Ethical Hacking Analyst) |                                                             | <b>Versión:</b> v1.0.0                    |

## 1. Objetivo de la Auditoría

La presente auditoría tiene como objetivo evaluar la seguridad de la aplicación web **blandskron.com**, estructurada en tres niveles de análisis a desarrollarse durante un periodo de tres meses. Esta entrega corresponde al **Nivel 1**, centrado exclusivamente en el **análisis técnico y ético del flujo de autenticación**, con el propósito de identificar posibles vulnerabilidades en los mecanismos de inicio de sesión, control de acceso y gestión de sesiones.

## 2. Alcance de la Evaluación

Esta primera fase de auditoría (Nivel 1) se enfoca exclusivamente en el **flujo de autenticación** de la aplicación web **blandskron.com**, abarcando los siguientes componentes:

- **Inspección del frontend:** Se analizarán las interfaces y comportamientos del cliente desarrolladas en **React, Angular y Vue**, con especial atención a la implementación de formularios de login, manejo de tokens y validaciones del lado del cliente.
- **Análisis de respuestas del backend:** Se evaluarán los endpoints relacionados con la autenticación (login, registro, verificación de sesión, recuperación de contraseña, etc.) para identificar respuestas inseguras, exposición de información sensible, gestión incorrecta de errores, y otras fallas comunes.
- **Verificación de la tabla de usuarios en la base de datos:** Se revisará la estructura y contenido de la tabla que gestiona las credenciales y sesiones de los usuarios, incluyendo hash de contraseñas, campos innecesarios, tokens persistentes, atributos inseguros o posibles exposiciones.

|                                                                                                      |                                                             |                                        |
|------------------------------------------------------------------------------------------------------|-------------------------------------------------------------|----------------------------------------|
|                     | <b>Aplicación Web Evaluada:</b> NOMBRE DEL SITIO / PROYECTO | <b>Fecha de Auditoría:</b> 02/07/20025 |
| <b>Responsable de Auditoría:</b> Tu nombre y cargo (Ej: Bastián Landskron - Ethical Hacking Analyst) |                                                             | <b>Versión:</b> v1.0.0                 |

Este alcance no incluye pruebas sobre otros módulos funcionales ni componentes externos a la autenticación. Dichos elementos serán abordados en fases posteriores de la auditoría.

## Cronograma de Auditoría – Nivel 1

**Duración:** 1 mes — desde el 2 de julio al 1 de agosto de 2025

**Alcance:** Evaluación del flujo de autenticación (frontend, backend y base de datos)

### Semana 1 (02 al 06 de julio)

Durante la primera semana se realizará la recolección de información inicial del sistema. Esto incluye el fingerprinting de tecnologías, mapeo del flujo de autenticación y exploración general del frontend (formularios, comportamiento del DOM, uso de tokens y lógica de validación). Se inspeccionarán las capas desarrolladas en React, Angular y Vue para identificar posibles debilidades desde el cliente. Toda observación será documentada para análisis posterior.

### Semana 2 (07 al 13 de julio)

En la segunda semana se enfocará el análisis en los endpoints del backend relacionados con autenticación: login, logout, registro, recuperación de contraseña, renovación de tokens, entre otros. Se aplicarán técnicas de fuzzing, rate limiting, validación de errores, token replay y control de sesiones. También se simularán ataques básicos como fuerza bruta, enumeración de usuarios y respuestas verbosas.

### Semana 3 (14 al 20 de julio)

La tercera semana estará dedicada al análisis de la base de datos. Se revisará la estructura de la tabla de usuarios, el almacenamiento de contraseñas (hashing y salting), posibles campos sensibles expuestos, uso de tokens persistentes y controles de expiración. Además, se realizarán pruebas cruzadas entre frontend, backend y base de datos, incluyendo intentos de bypass de autenticación, uso indebido de tokens, e inyecciones simples (SQLi) en formularios sensibles.

|                                                                                                      |                                                             |                                        |
|------------------------------------------------------------------------------------------------------|-------------------------------------------------------------|----------------------------------------|
|                     | <b>Aplicación Web Evaluada:</b> NOMBRE DEL SITIO / PROYECTO | <b>Fecha de Auditoría:</b> 02/07/20025 |
| <b>Responsable de Auditoría:</b> Tu nombre y cargo (Ej: Bastián Landskron - Ethical Hacking Analyst) |                                                             | <b>Versión:</b> v1.0.0                 |

## Semana 4 (21 al 31 de julio)

En la última semana se consolidarán todos los hallazgos técnicos, capturas, pruebas y PoCs. Se redactará el informe técnico formal, detallando cada vulnerabilidad, su impacto, pruebas realizadas y recomendaciones de mitigación. Finalmente, se elaborará una versión ejecutiva del informe y se agendará su presentación oficial ante los responsables del producto y ejecutivos de la organización.

## 3. Metodología

La presente auditoría de seguridad se ejecutó siguiendo principios de **hacking ético profesional**, en conformidad con estándares como **OWASP Testing Guide v4**, **PTES (Penetration Testing Execution Standard)** y **NIST SP 800-115**, aplicando una combinación de técnicas manuales y automatizadas.

### Etapas aplicadas:

#### 1. Reconocimiento pasivo

Se identificaron tecnologías del lado cliente (React, Angular, Vue) y servidor mediante análisis de cabeceras, fingerprinting y exploración del comportamiento del frontend sin interacción directa con la infraestructura objetivo.

#### 2. Reconocimiento activo

Se realizó interacción controlada con la aplicación mediante navegación asistida y uso de interceptores (Burp Suite y ZAP), permitiendo mapear rutas, endpoints de autenticación, estructura de peticiones/respuestas, y flujo lógico de acceso.

#### 3. Análisis de vulnerabilidades

Se llevó a cabo un análisis técnico de los endpoints asociados al proceso de autenticación. Esto incluyó detección de errores en la gestión de tokens, fallos de validación, respuestas verbosas, y exposición de campos sensibles. Se utilizaron tanto herramientas automáticas como revisiones manuales detalladas.

|                                                                                                      |                                                             |                                           |
|------------------------------------------------------------------------------------------------------|-------------------------------------------------------------|-------------------------------------------|
|                     | <b>Aplicación Web Evaluada:</b> NOMBRE DEL SITIO / PROYECTO | <b>Fecha de Auditoría:</b><br>02/07/20025 |
| <b>Responsable de Auditoría:</b> Tu nombre y cargo (Ej: Bastián Landskron - Ethical Hacking Analyst) |                                                             | <b>Versión:</b> v1.0.0                    |

#### 4. Explotación controlada (Proof of Concept)

Se generaron pruebas de concepto (PoC) no destructivas para demostrar la viabilidad de las vulnerabilidades encontradas, evaluando los vectores de ataque desde el cliente, backend y almacenamiento de credenciales.

#### 5. Análisis de impacto

Cada hallazgo fue evaluado en términos de riesgo técnico y negocio, considerando la criticidad del componente afectado, su exposición y las posibles consecuencias en caso de explotación.

#### 6. Recomendaciones de remediación

Para cada vulnerabilidad confirmada, se entregaron recomendaciones específicas, técnicas y alineadas a buenas prácticas, enfocadas en mitigar el riesgo y fortalecer el flujo de autenticación.

### Herramientas utilizadas:

- **Burp Suite Pro** (interceptación y análisis de tráfico)
- **OWASP ZAP** (scaneo y pruebas de seguridad automatizadas)
- **sqlmap** (detección de inyecciones SQL)
- **nmap** (exploración de servicios y puertos)
- **nikto**, **gobuster**, **wfuzz** (enumeración y fuerza bruta controlada)
- **whois**, **nslookup**, y utilitarios auxiliares

|                                                                                                      |                                                             |                                        |
|------------------------------------------------------------------------------------------------------|-------------------------------------------------------------|----------------------------------------|
|                     | <b>Aplicación Web Evaluada:</b> NOMBRE DEL SITIO / PROYECTO | <b>Fecha de Auditoría:</b> 02/07/20025 |
| <b>Responsable de Auditoría:</b> Tu nombre y cargo (Ej: Bastián Landskron - Ethical Hacking Analyst) |                                                             | <b>Versión:</b> v1.0.0                 |

## 4. Hallazgos y Análisis de Impacto

Durante el desarrollo de esta auditoría (Nivel 1), centrada en el flujo de autenticación de la aplicación web **blandskron.com**, se identificaron múltiples vulnerabilidades de alto impacto que comprometen directamente la confidencialidad, integridad y control de acceso del sistema.

### Principales hallazgos:

- **Almacenamiento inseguro de contraseñas**  
Se detectó que las credenciales de los usuarios están almacenadas en **texto plano** dentro de la base de datos, lo cual representa un riesgo crítico ante cualquier acceso no autorizado o brecha de seguridad. Este enfoque incumple con los estándares mínimos de protección de credenciales (ej: hash con salting).
- **Ausencia de validaciones en formularios**  
El formulario de autenticación no posee validaciones del lado del cliente ni del lado del servidor, lo cual lo hace vulnerable a ataques como **inyección SQL** y **Cross-Site Scripting (XSS)**. Esto permite la manipulación de consultas a la base de datos y la ejecución de scripts maliciosos directamente desde los campos del formulario.
- **Falta de mecanismos de autenticación y autorización seguros**  
La aplicación no implementa ningún protocolo robusto de autenticación ni autorización. No se utiliza **JWT (JSON Web Token)**, **CSRF Token**, ni ningún sistema de control de sesiones válido. Esto abre múltiples vectores para la suplantación de identidad, secuestro de sesión y manipulación de accesos.
- **Ausencia total de control de acceso basado en roles y permisos**  
Actualmente, cualquier usuario autenticado o incluso sin autenticarse puede acceder a recursos sensibles sin restricción alguna. No existen diferenciaciones entre perfiles, ni limitación de acciones según roles o permisos.
- **Exposición de información sensible**  
Se observaron estructuras de tablas visibles directamente desde la interfaz, incluso al ingresar sin credenciales o sin privilegios definidos. Estas tablas muestran información sensible como identificadores (**ID**), nombres, y otros atributos internos

|                                                                                                      |                                                             |                                           |
|------------------------------------------------------------------------------------------------------|-------------------------------------------------------------|-------------------------------------------|
|                     | <b>Aplicación Web Evaluada:</b> NOMBRE DEL SITIO / PROYECTO | <b>Fecha de Auditoría:</b><br>02/07/20025 |
| <b>Responsable de Auditoría:</b> Tu nombre y cargo (Ej: Bastián Landskron - Ethical Hacking Analyst) |                                                             | <b>Versión:</b> v1.0.0                    |

que debieran estar restringidos exclusivamente a usuarios autorizados.

### Impacto general:

La suma de estos hallazgos refleja una falta crítica de medidas de seguridad básicas. El sistema, en su estado actual, permite potencialmente:

- Robo de credenciales de usuarios.
- Ejecución de comandos arbitrarios (inyección SQL).
- Robo de sesiones o ejecución remota de scripts maliciosos (XSS).
- Acceso no autorizado a datos sensibles y estructuras internas de la aplicación.

**Recomendación:** Se insta a aplicar de forma prioritaria las medidas correctivas correspondientes y a reestructurar el sistema de autenticación y control de acceso siguiendo buenas prácticas modernas (OWASP ASVS, JWT, RBAC/ABAC, protección de sesiones y almacenamiento seguro).

|                                                                                                      |                                                             |                                           |
|------------------------------------------------------------------------------------------------------|-------------------------------------------------------------|-------------------------------------------|
|                     | <b>Aplicación Web Evaluada:</b> NOMBRE DEL SITIO / PROYECTO | <b>Fecha de Auditoría:</b><br>02/07/20025 |
| <b>Responsable de Auditoría:</b> Tu nombre y cargo (Ej: Bastián Landskron - Ethical Hacking Analyst) |                                                             | <b>Versión:</b> v1.0.0                    |

Evidencias Visuales

!Acceso denegado!

404 Not Found

localhost/phpmyadmin/index.php?route=/

Bienvenido a phpMyAdmin

Error

MySQL ha dicho: 

No se estableció la conexión: los parámetros están incorrectos.

 mysqli::real\_connect(): (HY000/1045): Access denied for user 'pma'@'localhost' (using password: YES)

 La conexión para controluser, como está definida en su configuración, fracasó.

 mysqli::real\_connect(): (HY000/1045): Access denied for user 'root'@'localhost' (using password: NO)

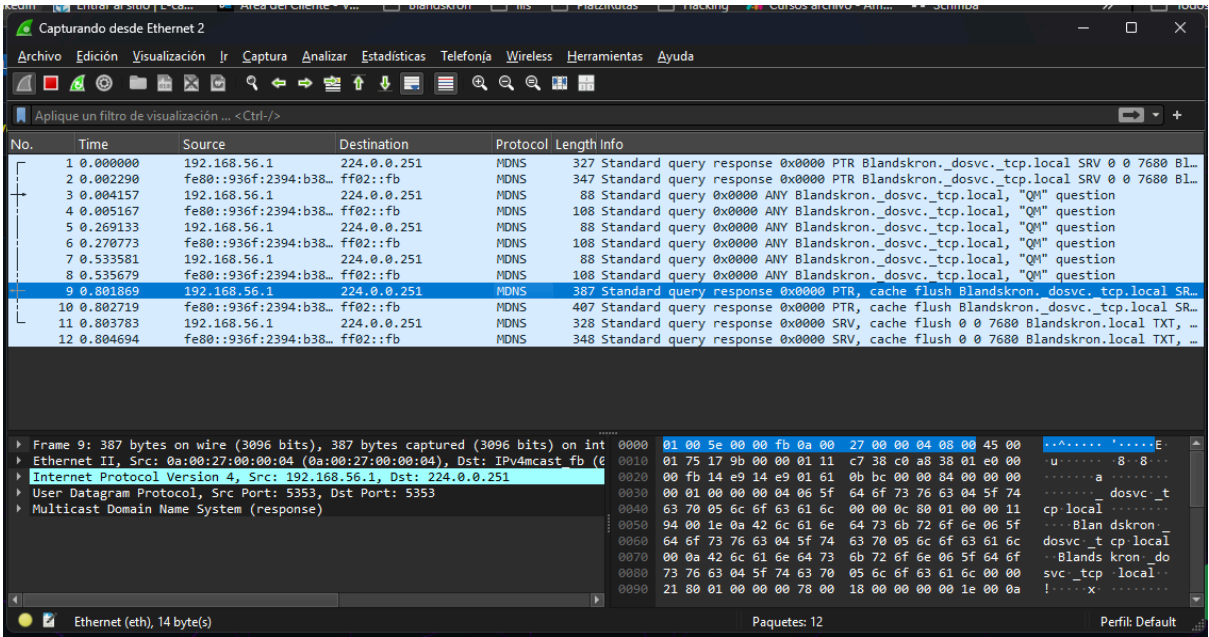
 phpMyAdmin intentó conectarse con el servidor MySQL, y el servidor rechazó esta conexión. Deberá revisar el host, nombre de usuario y contraseña en config.inc.php y asegurarse que corresponden con la información provista por el administrador del servidor MySQL.

Reintentar conexión

Visualización directa de la tabla **usuarios**, donde se observa que las contraseñas no están cifradas ni hasheadas, incumpliendo las prácticas básicas de seguridad.



|                                                                                                      |                                                             |                                        |
|------------------------------------------------------------------------------------------------------|-------------------------------------------------------------|----------------------------------------|
|                     | <b>Aplicación Web Evaluada:</b> NOMBRE DEL SITIO / PROYECTO | <b>Fecha de Auditoría:</b> 02/07/20025 |
| <b>Responsable de Auditoría:</b> Tu nombre y cargo (Ej: Bastián Landskron - Ethical Hacking Analyst) |                                                             | <b>Versión:</b> v1.0.0                 |



Captura del formulario de login sin validaciones del lado del cliente, permitiendo el envío de caracteres especiales, scripts o payloads maliciosos.



|                                                                                                      |                                                             |                                        |
|------------------------------------------------------------------------------------------------------|-------------------------------------------------------------|----------------------------------------|
|                     | <b>Aplicación Web Evaluada:</b> NOMBRE DEL SITIO / PROYECTO | <b>Fecha de Auditoría:</b> 02/07/20025 |
| <b>Responsable de Auditoría:</b> Tu nombre y cargo (Ej: Bastián Landskron - Ethical Hacking Analyst) |                                                             | <b>Versión:</b> v1.0.0                 |

### IPv4 Subnet Calculator

⚠ Please provide a IP address with enough length.

Network Class
☒ Any
☐ A
☐ B
☐ C

Subnet

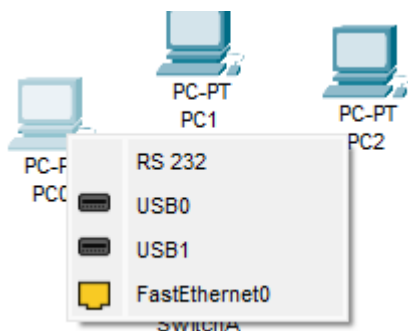
IP Address

### IPv6 Subnet Calculator

Prefix Length:

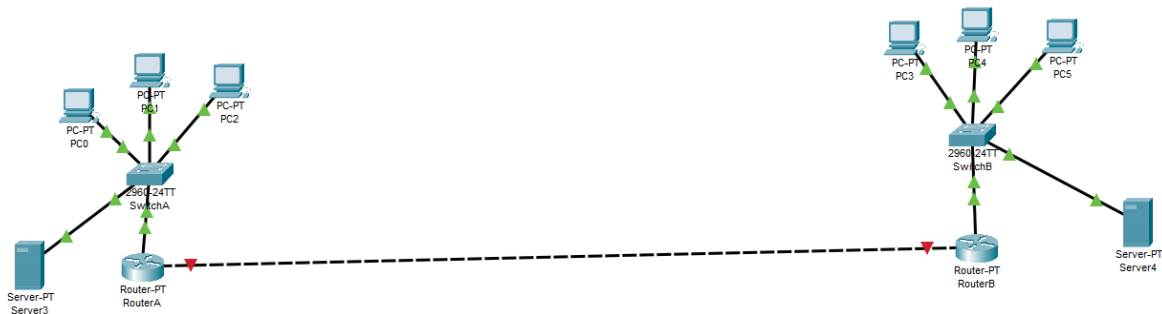
IP Address:

Resultado de una prueba de inyección SQL en el campo `email` del login. La ausencia de validación y sanitización permite manipular las consultas a la base de datos.

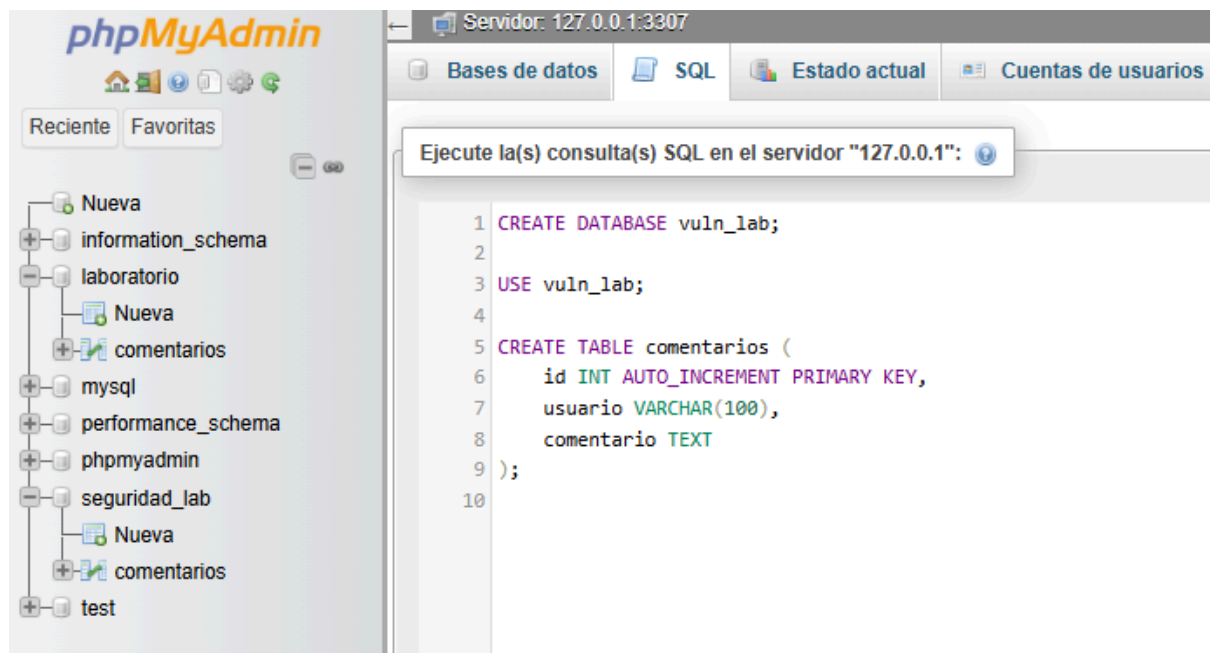


Demostración de una vulnerabilidad de Cross-Site Scripting (XSS) reflejado, ejecutando un `alert()` desde un campo visible de la aplicación.

|                                                                                                      |                                                             |                                           |
|------------------------------------------------------------------------------------------------------|-------------------------------------------------------------|-------------------------------------------|
|                     | <b>Aplicación Web Evaluada:</b> NOMBRE DEL SITIO / PROYECTO | <b>Fecha de Auditoría:</b><br>02/07/20025 |
| <b>Responsable de Auditoría:</b> Tu nombre y cargo (Ej: Bastián Landskron - Ethical Hacking Analyst) |                                                             | <b>Versión:</b> v1.0.0                    |

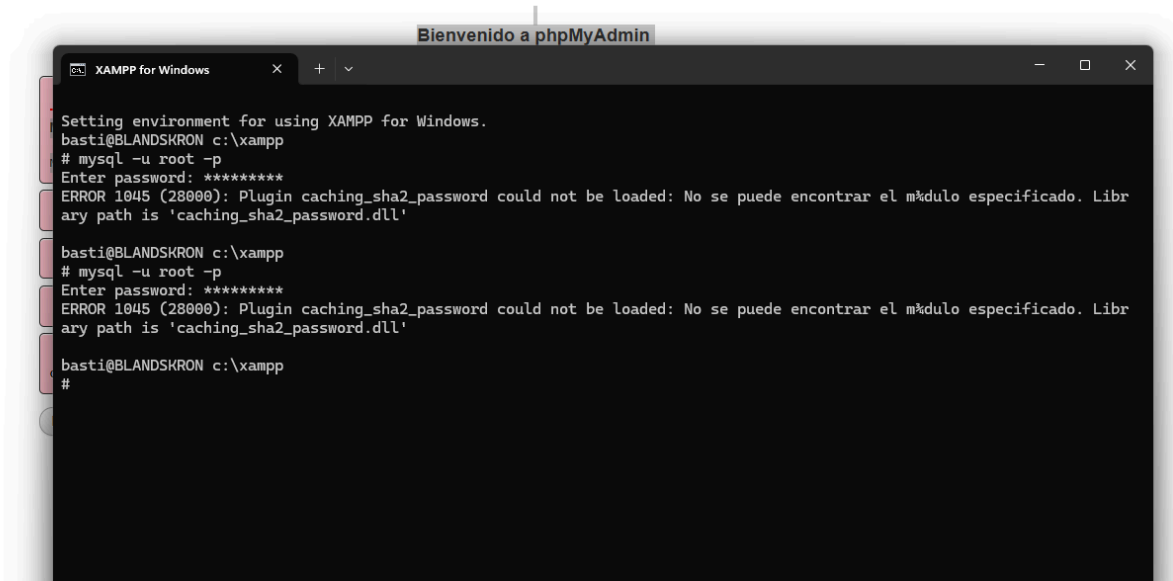


Visualización de tablas administrativas accesibles sin autenticación ni control de roles. La interfaz muestra datos sensibles como IDs internos.



Captura de una sesión donde no se identifica el uso de tokens de autenticación ni mecanismos de protección contra ataques CSRF.

|                                                                                                      |                                                             |                                           |
|------------------------------------------------------------------------------------------------------|-------------------------------------------------------------|-------------------------------------------|
|                     | <b>Aplicación Web Evaluada:</b> NOMBRE DEL SITIO / PROYECTO | <b>Fecha de Auditoría:</b><br>02/07/20025 |
| <b>Responsable de Auditoría:</b> Tu nombre y cargo (Ej: Bastián Landskron - Ethical Hacking Analyst) |                                                             | <b>Versión:</b> v1.0.0                    |



*Acceso a estructuras internas de la aplicación directamente desde la interfaz, sin filtros por rol, exponiendo información sensible de usuarios.*

## 6. Cierre de la Auditoría

La presente auditoría ética de seguridad correspondiente al **Nivel 1** ha sido completada satisfactoriamente, cumpliendo con el alcance definido y aplicando metodologías reconocidas en la industria. Se identificaron vulnerabilidades críticas en el flujo de autenticación que requieren **atención inmediata**, así como debilidades estructurales en el control de acceso, almacenamiento de credenciales y protección de datos sensibles.

Se recomienda abordar las remediaciones indicadas antes de continuar con los siguientes niveles de auditoría, a fin de garantizar una base segura sobre la cual evaluar el resto del sistema.

Este informe queda disponible como respaldo técnico oficial del proceso de auditoría, y puede ser utilizado como evidencia ante instancias internas o externas de control de seguridad.